**Disclaimer / Academic Notice:**

*This document is an independent, illustrative cybersecurity risk assessment and incident response playbook created solely for academic and professional portfolio purposes. It is based entirely on publicly available open-source intelligence (OSINT), forensic reports, and media investigations regarding the 2016 Bangladesh bank cyber incident. The author has no affiliation with Bangladesh Bank, and this document does not utilize any non-public, proprietary, or internal network data.*

9/12/2025

# Bangladesh Bank Post-Incident Risk Assessment Report & SWIFT-Related Cyber Fraud Incident Response Playbook

Lead Assessor: Adam Bello Ahmad

# Contents

Part A: Risk Assessment ..... 4
Introduction & Company Overview ..... 4
Risk Assessment Context & Objectives ..... 5
Internal and External Context ..... 5
Scope ..... 5
Risk Assessment Methodology & Results Summary ..... 6
Risk Assessment Matrix ..... 8
Top Two At-Risk Assets ..... 9
Asset-Based Assessment & Summary ..... 10
__Mitigation Strategies ..... 13
Risk Treatment Plan ..... 14
Part B: Incident Response Playbook ..... 15
Introduction & Overview ..... 15
Incident Response Steps ..... 16
_Flowchart Diagram ..... 19
Tools & Resources ..... 20
Lessons Learned ..... 20
__Recommendations ..... 21
REFERENCES ..... 24

# Part A: Risk Assessment

**Post-Incident Risk Assessment of Bangladesh Bank's Security Posture Following the 2016 Heist**

## Introduction & Company Overview

The purpose of this report is to present the findings of a risk assessment exercise carried out from **November 17th, 2025** to **December 5th, 2025**, within the scope defined in the sections that follow. The aim of this assessment is to identify the risks affecting **Bangladesh Bank**, determine which risks can be accepted, and highlight those that require mitigation to protect the bank's critical financial operations, information assets, and business continuity.

**Bangladesh Bank**, the central bank of Bangladesh, oversees monetary policy, manages the country's foreign reserves, and facilitates international financial transactions through the **Society for Worldwide Interbank Financial Telecommunication (SWIFT) System**. As a financial regulator and national banking institution, it operates an ICT environment that supports payment processing, interbank transfers, reserve management, and internal administrative functions. Its position in the global financial system makes it a high-value target for cyber-enabled fraud and state-level threat actors.

In February 2016, the bank experienced a major cyber incident in which attackers infiltrated its internal network, gained access to the SWIFT payment environment, and issued fraudulent transfer requests amounting to nearly USD 1 billion. A combination of phishing, weak internal controls, poor network segmentation, outdated systems, and the compromise of SWIFT operator credentials enabled the attackers to move laterally, deploy malware, disable transaction-verification mechanisms, and transmit unauthorized payment instructions. The incident resulted in a confirmed loss of USD 81 million, significant reputational damage, and global scrutiny of the bank's cybersecurity posture. This real-world event forms the basis of this assessment.

Upon approval of this risk assessment report, mitigation actions and treatment strategies will be identified, evaluated, and incorporated into a formal **risk treatment plan**, forming part of Bangladesh Bank's Information Security Management System (ISMS). This ensures a structured and proactive approach to reducing risk exposure, strengthening internal controls, and preventing a recurrence of similar incidents.

The process followed for this assessment aligns with the **Risk Assessment and Treatment Process** defined in the bank's ISMS framework, which provides the methodology for evaluating threats, vulnerabilities, and impacts across critical assets. This report describes: the context and scope of the risk assessment the assets within scope the threats and vulnerabilities affecting those assets

This document serves as an input to the risk treatment stage and must be reviewed and approved by senior management prior to implementation. The assessment was conducted by the following individual:

| NAME | ROLE IN ASSESSMENT |
|---|---|
| Adam Bello Ahmad | Lead Risk Assessor |

*Table 1: Risk assessment Individual*

No external consultations were conducted during this risk assessment; all analysis and findings were performed by the Lead Risk Assessor.

## Risk Assessment Context & Objectives

This risk assessment was carried out to evaluate the ICT infrastructure and internal network security of Bangladesh Bank following the 2016 SWIFT cyber heist. It focuses on identifying risks related to internal controls, access management, network segmentation, monitoring, and staff awareness, which contributed to the unauthorized transactions.

The main objectives of this risk assessment report include:

- To identify and evaluate potential risks to Bangladesh Bank's critical ICT systems and operations, including risks arising from deficiencies in internal controls, malware propagation, phishing susceptibility, and access management weaknesses.
- To prioritize identified risks based on their potential impact on financial loss, operational disruption, reputational damage and the likelihood of their occurrence.
- To develop actionable mitigation strategies and recommend improvements to internal controls, network security, and staff awareness programs.

## Internal and External Context

This risk assessment was carried out to evaluate risks affecting Bangladesh Bank's ICT infrastructure and internal network security following the 2016 SWIFT cyber heist, which created both internal and external pressures for a thorough review. Internally, the assessment is needed to identify vulnerabilities, assess the effectiveness of existing controls, and prioritise risks that could impact financial operations, operational continuity, and regulatory compliance. Externally, the incident highlighted growing industry-wide cyber threats, heightened regulatory expectations, and increased scrutiny from international financial partners, all of which make this assessment necessary.

The assessment provides benefits including improved risk awareness, strengthened internal controls, informed decision-making for mitigation strategies, and enhanced preparedness against future cyber incidents

## Scope

This risk assessment addresses the risks to Bangladesh Bank's ICT infrastructure and internal network security that support SWIFT operations and related financial transaction processes. It includes critical assets such as SWIFT Terminals, SWIFT operator credentials, transaction

verification mechanisms, network segmentation, monitoring and logging systems, and staff awareness related to phishing and social engineering.

The assessment does not cover systems unrelated to SWIFT operations or core banking processes, including customer-facing applications, ATM networks, physical security of branches or vaults, or any external organizations not directly involved in the 2016 cyber incident.

This boundary ensures that the assessment remains focused on the assets and processes that were exploited during the 2016 cyber incident while providing actionable recommendations to mitigate similar risks in the future.

## Risk Assessment Methodology & Results Summary

The methodology applied in this assessment combines the NIST Cybersecurity Framework (CSF) with the MITRE ATT&CK framework. NIST CSF provides the structure for identifying, analysing, and managing risks across critical assets, while MITRE ATT&CK supports the evaluation of threat likelihood by referencing real-world adversary techniques observed in incidents similar to the 2016 cyber heist. This blended approach ensures the analysis is both control-focused and grounded in practical threat behaviour.

### i. Data Gathering

The assessment begins by collecting information from publicly available and verifiable sources regarding the 2016 Bangladesh Bank incident. Data was primarily gathered through Open-Source Intelligence (OSINT), which included reputable public news outlets, documentary-style cyber incident reports, and forensic analyses publicly available (Rahman, 2016; Zetter, 2016; Forbes Staff, 2016). Additional background information was obtained from platforms such as Wikipedia and cybersecurity-focused podcasts and series (Darknet Diaries, 2020; Wikipedia, 2025). These sources provide enough factual detail to understand attacker behaviour, system weaknesses, and the sequence of events leading to the SWIFT compromise.

### ii. Asset Identification

Following the information gathering phase, the assessment proceeded to identifying all critical assets within the specified scope. These assets identified are the SWIFT terminals, SWIFT operator credentials, the transaction-verification process, internal network segmentation, monitoring and logging systems, and employees, including SWIFT operators and other staff whose credentials, actions, or awareness affect SWIFT operations and transaction verification.

Identifying these assets ensures that the assessment remains focused on the components that are directly involved in SWIFT operations and most likely to cause significant harm if compromised.

### iii. Threat Identification

Threats were identified by analysing documented attacker behaviour from the 2016 incident and comparing it with MITRE ATT&CK techniques commonly used by adversaries. In this case, the attackers gained access through a targeted socialengineering campaign that enabled them to deploy multiple malware

components: one backdoor, one encrypted channel for data exfiltration through that backdoor, and another used for network-wide reconnaissance. This allowed them to locate SWIFT workstations and obtain valid SWIFT operator credentials. With these credentials, they authenticated as legitimate users, deployed additional malware to move laterally, maintain persistence, and monitor internal activity. The malware further disrupted verification processes by manipulating the transaction-printing mechanism, preventing operators from detecting fraudulent transfers. The adversaries also took advantage of limited monitoring, weak logging, and reduced weekend oversight to remain undetected while issuing unauthorised SWIFT transactions.

These behaviours represent the key threats relevant to the current assessment and align with known adversary tactics and techniques documented in the MITRE ATT&CK framework (see Appendix A for the detailed mapping).

**iv. Impact Evaluation and Risk Prioritisation**

Each identified threat is assessed against its potential impact on the bank, measured across two key dimensions: financial, operational, and reputational. Financial impact focused on direct monetary loss, using the USD 81 million withdrawn in the 2016 heist as a reference point. Operational impact examined how an attack could interrupt payment processing, distort transaction records, or disable verification mechanisms such as the printer that confirms SWIFT transactions. Reputational impact measured how a breach could affect public confidence in the central bank; as the country's monetary authority, any sign of weak security raised broader doubts about the stability of the entire financial sector. The bank faced internal criticism and growing public distrust, and the governor's resignation shortly after the incident further intensified concerns about the bank's overall security posture. These impacts were then assigned to an Impact Rating Scale that reflects how deeply each risk could harm the institution.

With the impact values established, risks were prioritised by combining their impact severity with their likelihood of occurring. Impact was judged from existing control gaps, past incidents, and the ease with which attackers could exploit exposed systems or weak processes. Threats with both high impact and likelihood, such as credential compromise, manipulation of SWIFT instructions, and failure of monitoring controls, were placed at the top of the priority list. This ensured that the most damaging and most probable risks are addressed first, before moving to lower-level risks.

**Application to Bangladesh Bank**

The NIST Cybersecurity Framework and the MITRE ATT&CK Framework are applied to Bangladesh Bank by first identifying and categorising its key assets, which include SWIFT terminals, operator credentials, the transaction verification process, internal network segments supporting SWIFT operations, monitoring and logging systems, and employees whose credentials, actions, or awareness affect SWIFT operations and transaction verification. NIST is used to examine each asset for vulnerabilities and assess the level of risk it faces. MITRE ATT&CK is then used to map these assets to real-world attack techniques, illustrating how attackers could exploit weaknesses. This combined approach highlights the most exposed systems and personnel,

informs risk prioritisation, and provides a basis for the recommendations given in line with the NIST framework.

**Results Summary**

The assessment of Bangladesh Bank's SWIFT operations identified critical assets including SWIFT terminals, operator credentials, transaction verification processes, internal network segments, monitoring systems, and relevant personnel. Threat analysis revealed that attackers exploited social-engineering techniques and deployed malware for persistent access, lateral movement, and manipulation of transaction verification processes. Weak monitoring, logging, and weekend oversight allowed fraudulent transactions to go undetected. The impact of these threats is significant across financial, operational, and reputational dimensions, with the highest-priority risks involving credential compromise, manipulation of SWIFT instructions, and insufficient monitoring controls. Mapping these findings to the NIST CSF and MITRE ATT&CK frameworks highlights the most exposed systems and processes, as well as providing a basis for appropriate recommendations.

## Risk Assessment Matrix

| REF | ASSET | Threat 1 | Threat 2 | Threat 3 | Average or Asset's Risk Score |
|---|---|---|---|---|---|
| **1.** | Monitoring and Logging System | Stealth malware evading detection (5 × 5 = 25) | Long-term unauthorized presence (4 × 5 = 20) | Undetected encrypted exfiltration (4 × 4 = 16) | 20.33 (25 + 20 + 16)/3 |
| **2.** | SWIFT Operator Credentials | Credentials captured through keystroke logging (5 × 5 = 25) | Credentials accessed through phishing (4 × 5 = 20) | Credentials stolen from Password Stores (3 × 5 = 15) | 20 (25 +20 +15)/3 |
| **3.** | SWIFT Terminals | Workstation accessed through phishing (4 × 5 = 20) | Workstation compromised via malicious website visit (watering hole attack) (4 × 5 = 20) | Workstation compromised via malicious program installation (3 × 5 = 15) | 18.33 (20 + 20 + 15)/3 |
| **4.** | Transaction Verification Process (Including Verification Printer) | Insufficient controls for large scale transaction requests (4 × 5 = 20) | Log tampering (4 × 5 = 20) | Transactions altered in transit (3 × 5 = 15) | 18.33 (20 + 20 + 15)/3 |

| | | | | | |
|---|---|---|---|---|---|
| **5.** | Internal Network Segments (poor segmentation) | Lateral movement (no VLAN segmentation) (5 × 4 = 20) | Passive network sniffing (4 × 5 = 20) | Active network scanning (4 × 3 = 12) | 17.33 (20 + 20 + 12)/3 |
| **6.** | Employees (human factor) | Lack of cybersecurity awareness (5 × 4 = 20) | Employee negligence (4 × 4 = 16) | Malicious insider activity (2 × 5 = 10) | 15.33 (20 + 16 + 10)/3 |

*Table 3: Risk Assessment Matrix* The table below shows the rating scale used for interpreting the scores in the risk-assessment matrix. Each threat score was calculated by multiplying its likelihood value by its impact value.

| **Likelihood (1–5)** | **Description** | **Impact (1–5)** | **Description** |
|---|---|---|---|
| 1 – Rare | Highly unlikely; no known history of similar incidents | 1 – Insignificant | Negligible operational/financial impact; no regulatory consequences |
| 2 – Unlikely | Could occur but with minimal precedent; low probability | 2 – Minor | Limited disruption; small financial loss; minor recovery effort |
| 3 – Possible | Could occur under certain conditions; moderate probability | 3 – Moderate | Noticeable disruption; measurable financial loss; operational slowdown |
| 4 – Likely | Expected based on threats or existing vulnerabilities | 4 – Major | Significant interruption; high financial loss; reputational or regulatory impact |
| 5 – Certain | Very high probability | 5 – Severe | Critical compromise; extreme financial loss; regulatory breach; long-term impact |

*Table 4: Rating Scale*

## Top Two At-Risk Assets

**1. Monitoring and Logging System**

The Monitoring and Logging System emerges as the highest risk asset in the matrix, with an average score of 20.33. This rating is driven primarily by the severe threat of stealth malware evading detection, which alone reached a score of 25. Additional risks such as long-term unauthorized presence (20) and undetected encrypted exfiltration (16) further elevate the overall risk level. The likelihood values are high because, at the time of the incident, the bank operated with minimal oversight into system activities, gaps in log management, and no realtime alerting capability. These weaknesses made it possible for attackers to maintain persistent access without being detected, especially during periods of reduced oversight such as weekends. The impact is also critical, as weak monitoring directly allows fraudulent transfers, data manipulation, and extended attacker presence in the network, each of which increases financial loss and reputational damage. The poor effectiveness of this system makes

the bank lose the ability to detect or investigate malicious behaviour, making any attack far more damaging and difficult to contain. Given its top position in the risk matrix, strengthening this asset aligns directly with the bank's broader risk-management objective of preventing undetected attacker activity and preventing repetition of the 2016 cyber incident.

**2. SWIFT Operator Credentials**

SWIFT Operator Credentials stand as the second most critical asset, with an average score of 20.00. This rating reflects the extremely high threat posed by credential capture through keylogging malware, which scored 25 (5 × 5). Other major threats, such as phishing-based credential harvesting (20) and theft from stored passwords (15), highlight how vulnerable these credentials were during the 2016 compromise. The likelihood of these threats is high because attackers could exploit weak storage practices, the absence of multi-factor authentication, and the ability to capture user keystrokes. The impact is equally severe, as compromised credentials allow attackers to authenticate as legitimate SWIFT operators and submit fraudulent transaction requests that appear valid. Thus, large-scale financial loss becomes possible if an attacker gains access to legitimate SWIFT operator credentials, because they can bypass verification controls and execute unauthorized transactions as if they were an authorized user. Compromise of these credentials directly threatens the bank's core financial operations and damages trust among local and international banking partners. Given its critical role in the bank's operations, this asset requires urgent attention, with emphasis on stronger authentication methods, secure credential management, and hardened workstations to prevent future compromises.

## Asset-Based Assessment & Summary

| REF | ASSET NAME & DESCRIPTION | TYPE (P/F/S) | THREATS (e.g. data breaches, DDoS attacks, malware) | ADDITIONAL COMMENTS |
|---|---|---|---|---|
| **1.** | **SWIFT Terminals:** Computers used to send and receive SWIFT messages and perform financial operations. | P | Compromise via phishing, malicious website visit (watering hole), or malware installation. | Compromise of SWIFT terminals could allow attackers to access the SWIFT network directly, manipulate transactions, or install malware. This would disrupt payment processing and increase the likelihood of unauthorized transfers. |

| | | | | |
|---|---|---|---|---|
| **2.** | **SWIFT Operator Credentials**: Usernames and passwords used by operators to authenticate and approve transactions. | F | Keylogging, phishing, theft from password stores. | If credentials are stolen or misused, attackers could issue fraudulent transactions that appear legitimate. This threatens core financial operations and could result in significant monetary loss. |
| **3.** | **Transaction Verification System (Including Printer)**: Processes and tools used to validate and print SWIFT transactions for operational verification. | F/P | Manipulation of verification process, insufficient authorization controls, log tampering. | If the transaction verification system gets compromised or disabled, fraudulent transactions may not be detected. This resulting failure will undermine the verification process by allowing unauthorized transfers to go unnoticed and increasing financial risk. |
| **4.** | **Monitoring & Logging System**: Systems that track activity, record logs, and alert operators to unusual or unauthorized behaviour. | F | Malware evading detection, long-term unauthorized presence, undetected encrypted exfiltration. | Weak or absent monitoring could allow attackers to stay in the system unnoticed for long periods. This would prevent the bank from detecting or investigating malicious activity, increasing the risk of large financial losses and operational disruption. |
| **5.** | **Internal Network Segment:** The portion of the bank's network supporting SWIFT operations, connecting SWIFT terminals, servers, and monitoring systems | F | Active network scanning, passive sniffing and lateral movement. | Switches are outdated and do not support proper segmentation, thus cannot prevent lateral movement. Additionally, there was no system in place to detect malware performing sniffing or network scans. |

| | | | | |
|---|---|---|---|---|
| **6.** | **Employees**: SWIFT operators, administrators, and staff whose actions or credentials affect SWIFT operations. | S | Negligence, malicious insider activity, lack of security awareness (phishing/social engineering) | Negligent or uninformed employees could fall victim to phishing or social engineering attacks, while malicious insiders could intentionally bypass controls. This could lead to credential compromise, unauthorized transactions, and operational disruption, as well as reputational damage. |
| **7.** | **SWIFT CSP Compliance Controls:** Mandatory control requirements from SWIFT (network isolation, MFA, logging). | F | Security gaps due to compromise or noncompliance with required SWIFT controls. | Adversaries will take advantage of missing controls as they can easily bypass authentication, move across the network, and tamper with SWIFT messaging without being detected. |
| **8.** | **Incident Response Process:** The bank's procedures for identifying, escalating, analysing, and containing cyber incidents. | F | Delayed or ineffective response to active attacks. | If the process is weak or undefined, attackers will remain active for long periods and complete fraudulent transactions before any action is taken. |
| **9.** | **Recovery Process (Technical & Financial):** The bank's ability to restore affected systems, recover corrupted data, reverse unauthorised transactions, and return operations to normal after a cyber incident. | F | Inability to recover quickly after cyber incidents. | If this process fails, the bank may suffer extended downtime, unrecoverable financial losses, and slow restoration of critical SWIFT operations. |

*Table 4: Risk assessment results summary (asset-based)*

## Mitigation Strategies

1. **Monitoring & Logging System**

   Strengthening this capability is essential because undetected activity was the core weakness that allowed the attackers to remain inside the network for an extended period. The bank can significantly reduce this risk by improving visibility, automating alerts, and ensuring logs cannot be tampered with. Introducing centralised log management, real-time monitoring and anomaly-detection tools will make it far harder for malware to remain hidden or for attackers to maintain long-term presence in the system.

   Once these improvements are in place, suspicious activity can be identified much earlier, unusual behaviour becomes easier to investigate, and the bank gains a reliable trail of evidence for incident response. The overall effect is a significant reduction in the adversary's ability to operate silently while increasing the bank's ability to contain threats before financial or operational damage occurs.

2. **SWIFT Operator Credentials**

   The risks associated with SWIFT Operator Credentials can be reduced by strengthening how these credentials are created, stored, and used. Enforcing multi-factor authentication for every SWIFT login adds a critical barrier that prevents attackers from using captured or stolen passwords, since access would now require a second factor tied to the legitimate operator.

   Introducing strict password-rotation policies ensures that SWIFT credentials cannot remain static for long periods, reducing the window of opportunity for attackers who manage to harvest them. When rotation is paired with stronger password-creation requirements and secure storage, the credential lifecycle becomes far more resistant to theft or reuse. The expected outcome is a steady decline in successful credential-based intrusions.

   Additionally, restricting the use of SWIFT operator accounts to approved working hours further limits exposure. Any login attempt outside these hours require explicit authorization. By binding credential usage to predictable operational periods, the bank reduces the likelihood of covert after-hours access, which was a key tactic in the earlier compromise.

   Bringing these strategies together transforms SWIFT Operator Credentials from high-risk to tightly controlled assets, reducing the likelihood of compromise and ensuring attackers cannot authenticate as legitimate operators even if they acquire a password.

## Risk Treatment Plan

| REF | **Risk (including the asset it belongs to)** | **Treatment Strategy** | **Implementation** |
|---|---|---|---|
| **1** | Compromise of **SWIFT Terminals** through phishing, watering-hole attacks or malware, allowing attackers to manipulate SWIFT messages | Mitigation | Protect SWIFT terminals by strengthening the systems around them. Install strong antimalware and endpoint protection, and ensure terminals run on hardened, locked-down images. Place the SWIFT environment behind a dedicated firewall that filters malicious traffic before it ever reaches the terminals. Add strict email-filtering controls to block phishing or malware delivery. |
| **2** | Theft or compromise of **SWIFT Operator Credentials** via phishing, keylogging or passwordstore theft, enabling fraudulent transactions | Mitigation | Protect SWIFT operator credentials by enforcing MFA for all logins and introducing regular password rotation. Limit account usage to approved working hours, with after-hours access allowed only through special authorization. This reduces the risk of attackers using stolen credentials. |
| **3** | Manipulation or tampering of the **TransactionVerification Process and Printer**, including bypassed controls or altered verification logs | Mitigation | Dual-control verification; secure tamperevident printer handling; digitally signed verification outputs; immutable logging; mandatory secondary reconciliation for high-value transactions. |
| **4** | Long-term undetected attacker presence due to weak **Monitoring & Logging Systems**, evasion, or log tampering | Mitigation | Strengthen monitoring so suspicious activity cannot go unnoticed. Use centralised log management with real-time alerts, and ensure logs cannot be altered or deleted. Add automated tools that detect abnormal behaviour. These improvements allow the bank to catch threats earlier, investigate unusual patterns quickly, and maintain a reliable trail of evidence. |
| **5** | Negligence, social engineering or malicious actions by **Employees** (SWIFT operators, administrators, staff) | Mitigation | Provide continuous awareness training and carry out background checks where necessary. Separate key duties so no single person has full control. Monitor for unusual |
| | leading to credential loss or unauthorized actions | | behaviour and clearly define penalties for misconduct. |

| | | | |
|---|---|---|---|
| **6** | Missing or weak **SWIFT CSP Compliance Controls**, allowing attackers to bypass authentication or move laterally | Mitigation | Perform a full review to identify gaps in SWIFT CSP requirements. Implement all mandatory controls, including MFA and network isolation. Bring in third-party auditors and keep compliance monitored continuously |
| **7** | Delayed, weak or undefined **Incident Response Process**, giving attackers time to complete fraudulent transfers | Mitigation | Create a clear incident response plan focused on SWIFT-related attacks. Define roles, responsibilities, and escalation steps. Run regular simulation exercises and keep a forensic or IR team on standby |
| **8** | Inability of the **Recovery Process** to restore systems, reverse unauthorized transactions or resume SWIFT operations quickly | Mitigation | Set up a strong monetary-recovery process that can act quickly after fraudulent transactions. This includes freezing the receiving bank accounts, notifying correspondent banks immediately, and alerting law-enforcement agencies as soon as suspicious transfers are identified. Ensure backups and disaster recovery plans are tested so SWIFT operations can resume quickly. |

# Part B: Incident Response Playbook

### Bangladesh Bank SWIFT-related Cyber Fraud Incident Response Playbook

## Introduction & Overview

An incident response playbook is a structured guide used to manage cyber incidents from the moment they are detected until systems are fully recovered. Its purpose is to ensure that every stage of a cyber incident is handled quickly, consistently and in a way that protects the organization's most critical operations. For an institution such as Bangladesh Bank, which manages national currency reserves and depends on SWIFT for international transfers, a welldefined playbook is essential for maintaining operational continuity and preventing large-scale financial losses.

This playbook focuses on **SWIFT-related cyber fraud incidents**, a type of cyber-attack where adversaries gain access to a bank's SWIFT environment, compromise operator accounts, and send fraudulent transfer instructions. This incident type is directly relevant to Bangladesh Bank because the 2016 cyber heist demonstrated how quickly attackers can take advantage of weak internal controls, poor monitoring, and compromised credentials to issue unauthorized transactions worth millions of dollars. By creating a playbook built around this specific threat, the bank strengthens its ability to detect, contain, and recover from any future SWIFT-related fraud attempts.

## Incident Response Steps

The incident response process is arranged step-by-step from detection to full recovery. Each step has a clear purpose, specific actions tied to the SWIFT environment, and the job role responsible for carrying it out.

1. **Detection (SWIFT Operator / SOC Analyst)**

   **Purpose:** Identify and immediately report any unusual behavior or failures in critical SWIFT operations.

   **SWIFT Operator**

   - Reports immediately any missing transaction confirmations or unexpected system errors that block the normal output of records.
   - Reports unexpected workstation reboots or any system anomalies that suggest remote control or physical tampering.

   **SOC Analyst**

   - Detects any abnormal activity such as unusual login or access patterns within the SWIFT environment.
   - Detects unexpected transaction-request message volumes or deviations from normal transaction behaviour.

   **Next Steps**: Immediate Triage and Action

   - If an anomaly is detected but not clearly malicious, the Operator or Analyst informs the SOC Lead and proceeds to **Step 2 (Verification)**.
   - If the event shows **clear indicators of compromise or malicious intent**, the Operator or Analyst alerts the SOC Lead immediately and skip directly to Step 3 (Containment), and Step 4 (Escalation) concurrently.

2. **Verification of Incident (SOC Lead / Cybersecurity Analyst)**

   **Purpose:** Confirm whether the observed activity is benign or malicious.

   - Review system logs
   - Check the **SWIFT Alliance Access Logs** for outgoing unusual customer payments or interbank transfers.
   - Verify internal payment approvals.
   - Review the specific terminal's activity records.

   **Next Steps**:

   - If YES (confirmed threat): Move to Containment (Step 3) and Escalation (Step 4) immediately and concurrently.
   - If NO (false positive): Document the event fully and return to normal monitoring.

3. **Containment (IT Security Manager / IT Operations Lead)**

   **Purpose:** Stop financial loss and isolate all affected systems immediately to prevent further damage.

   - **Emergency SWIFT Gateway Isolation Protocol:** Physically disconnect the main SWIFT gateway by unplugging the red-tagged network port from the core switch that links it to the internal network.
   - **Local Containment**: Disconnect all compromised computers, lock out all affected user accounts and immediately block any suspicious traffic on the firewall.

- **Financial Halt:** The IT Operations Lead, **upon immediate executive authorization (from the CISO/Governor's Office)**, contacts correspondent banks to issue **Stop/Recall** instructions to freeze or recover any suspicious outgoing bank transfer messages.

**4. Incident Escalation & Communication (CISO / Executive Management / External Parties)**

**Purpose**: Immediate, structured reporting to manage legal, regulatory, and public relations impact.

- **Internal**: The CISO briefs the Governor's office, Executive Management, and the internal Legal/Fraud Response Team.
- **Externa**l: Notify the global SWIFT Customer Security Programme (CSP), support team, relevant correspondent banks, national law enforcement (Financial Crimes Unit), and international partners (Interpol). The focus is on freezing correspondent's account and coordinating a multinational investigation.

**5. Investigation (Digital Forensics Team)**

**Purpose**: Analyze the attack vector, tools, and total impact on systems.

- **Evidence Collection**: Extract data (disk images and memory dumps) of affected SWIFT servers and terminals.
- **Analysis**: Examine server logs for hidden malware activity, signs of data deletion, and tampered records related to transaction history.
- **Tracing**: Search endpoints for unauthorized remote access tools, keyloggers, and evidence showing movement across the internal network.

**6. Eradication of Threat (IT Security Manager / Forensics Lead)**

**Purpose**: Eliminate all malicious code, artifacts, and close the exploited security gaps.

- **Eliminate** all identified malware, backdoors, and malicious files.
- **System Hardening**: Patch all exploited vulnerabilities, correct system misconfigurations, and reset weak or compromised passwords.
- **Ensure** all transaction and system logging mechanisms are fully operational and secured against tampering or modification.

**Step 7 Prerequisites:** the CISO must confirm that all eradication actions have been fully completed, validated, and documented. If any malicious persistence, misconfiguration, or unremediated vulnerability remains, Step 6 must continue until the environment is confirmed clean.

**7. System Recovery & Restoration of SWIFT Operations (**IT Operations Lead**)**

**Purpose:** Bring SWIFT back online safely and rebuild trust.

- Rebuild compromised SWIFT workstations using verified clean system images.
- Reset all SWIFT operator authentication mechanisms.
- Re-secure the message-approval environment by ensuring no unauthorized signing components remain active.
- Reconcile all pending or suspicious transactions with correspondent banks before normal operations resume.

- Reconnect SWIFT in phases: start with isolated testing, then move into fully monitored production.
- CISO signs off that SWIFT is stable, verified, and cryptographic trust is fully restored.
- Maintain heightened monitoring for a defined period (30–90 days) to ensure no persistence remains.

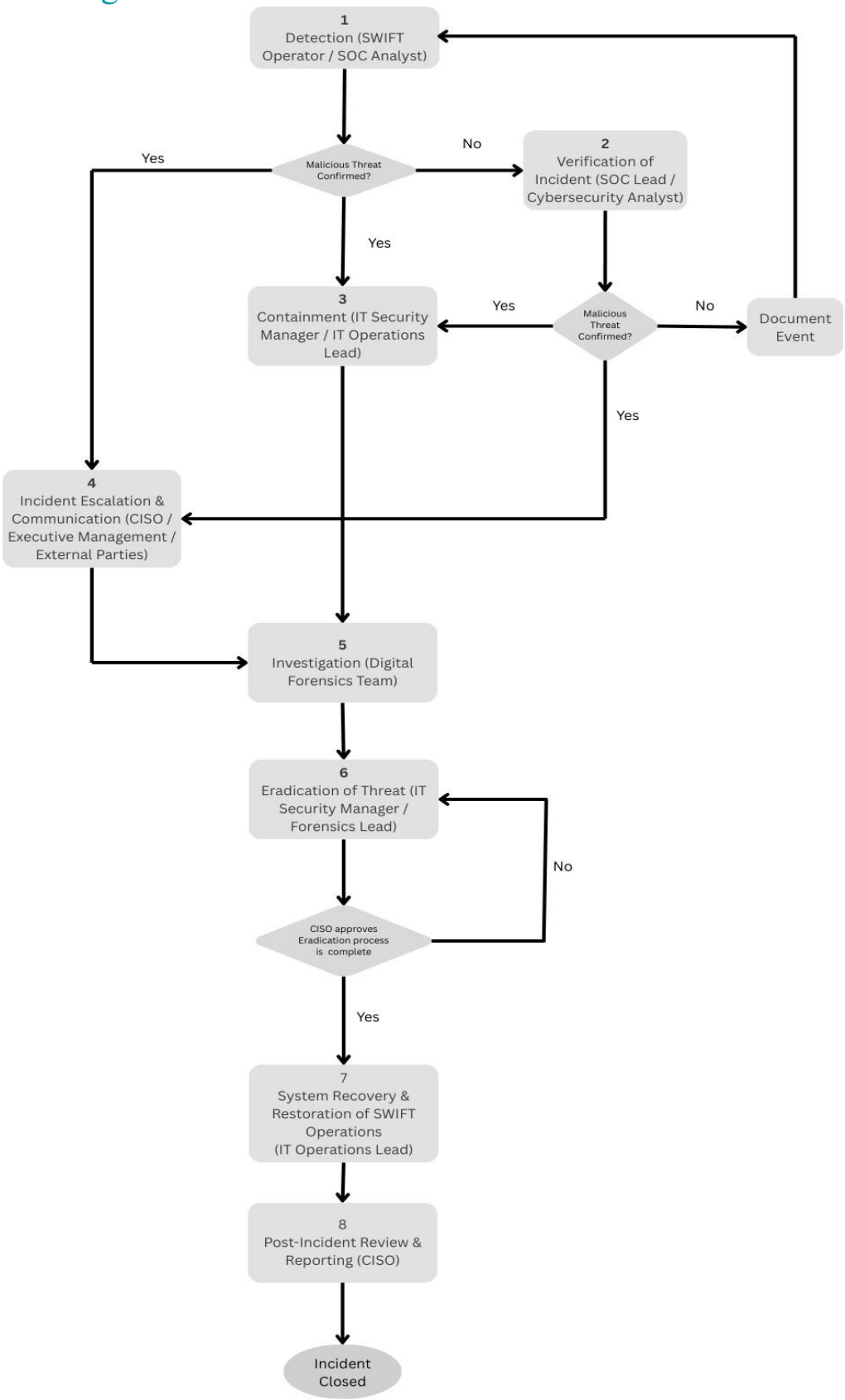
**Next Steps:** Once recovery is complete and SWIFT is operating in a stable, secure, and fully verified state, proceed to Step 8.

**8. Post-Incident Review & Reporting (**CISO**)**

**Purpose:** Close the incident and strengthen the institution.

- Hold a formal lessons-learned session (timeline, control failures, decisions, what worked/failed).
- Prepare the final executive report covering the impact, root cause, forensics findings, and all actions taken.
- Establish a remediation plan with clearly assigned responsibilities, deadlines, and verification steps.
- Update relevant policies, procedures, and the IR playbook based on lessons learned.
- Schedule training/tabletop exercises to reinforce new procedures.
- Store forensic evidence securely according to legal retention requirements.

# Flowchart Diagram




,

## Tools & Resources

Essential tools and resources Incident Response (Step 1 to Step 8):

1. **SIEM Tool**: monitors logs and alerts for unusual or suspicious activity across SWIFT systems.
2. **Endpoint Protection / EDR**: detects malware, ransomware, and suspicious behavior on SWIFT terminals and servers.
3. **SWIFT Monitoring Tools**: monitors SWIFT transaction activity, queues, and message integrity.
4. **Network IDS/IPS**: identifies malicious or anomalous network traffic in real-time.
5. **Log Management Tool**: centralizes and reviews system and SWIFT logs for forensic and verification purposes.
6. **SWIFT Alliance Access Logs**: provides detailed message queues and approval history for transaction verification.
7. **Access Audit Tool / Privileged Access Monitoring**: tracks and verifies privileged user activity on SWIFT terminals.
8. **Firewall**: blocks unauthorized connections and malicious traffic from compromised or suspect endpoints.
9. **Network Access Control (NAC)**: isolates affected SWIFT terminals or segments to contain threats.
10. **Emergency Contact Information**: NFU, Interpol, Correspondent Banks, SWIFT CSP; critical for escalation and coordination.
11. **Secure Forensic Toolkit**: captures memory, disk images, and artifacts for detailed forensic analysis.
12. **Patch Management / System Update Tool**: applies security patches and closes exploited vulnerabilities.
13. **Backup & Recovery System (e.g., Veeam)**: restores clean system states for safe recovery after eradication.
14. **Clean System Images**: verified, trusted images for rebuilding SWIFT terminals.
15. **Test Environment / Sandbox**: safely tests SWIFT system configurations or updates before reconnecting to production.
16. **Documentation Tools**: records all investigation steps, actions, lessons learned, and preparing final reports.

## Lessons Learned

This incident reveals how a motivated adversary can exploit a chain of small weaknesses to deliver a high-impact financial fraud. The tactics were not unusual: targeted phishing, credential capture, network infiltration and unauthorized SWIFT message crafting. What made it successful was the combination of gaps across people, processes and technology. Staff were not prepared to identify unusual transaction behaviour. Endpoint defences were minimal. Logging was insufficient and monitoring lacked real-time alerting. Even the physical printer used for SWIFT confirmation messages became a single point of failure that delayed detection.

The lesson is simple: this incident shows how important it is to verify controls continuously, enforce strict segregation around payment systems, and treat every privileged credential as a potential weakness. A future-ready organization will not only deploy controls but constantly test them, simulate fraud scenarios and anticipate adversaries rather than react to them.

## Recommendations

Strengthening the Monitoring and Logging System is paramount, as undetected activity allowed attackers to persist during the 2016 incident. The bank should implement centralized, tamper-proof log management with real-time alerts for anomalies in transactions, user access, and system behaviour, including off-hours activity. Automated detection tools capable of identifying stealth malware, long-term unauthorized presence, and encrypted exfiltration should be deployed, and regular testing should ensure continuous effectiveness, particularly during periods of low oversight.

SWIFT Operator Credentials and terminals require urgent protection due to their critical role in financial operations. Multi-factor authentication should be enforced for all operator accounts, with strict password rotation and secure storage. Account usage should be restricted to approved operational hours, with explicit authorization for after-hours access. Terminals must run on hardened with endpoint protection and be placed behind dedicated firewalls and email/web filtering controls to prevent phishing, malware, or watering-hole attacks. Network isolation between SWIFT systems and corporate infrastructure is essential to limit lateral movement and exposure.

The Transaction Verification System must be upgraded, as relying solely on the printer proved insufficient during the 2016 incident when it produced blank outputs. The printer should be hardened to prevent tampering, but additional verification measures are also required. Real-time alerts should flag anomalies in transaction requests, and a secondary approval process should be implemented for high-value transactions to ensure any irregularities are immediately detected.

Internal network segmentation should be improved and supported by IDS/IPS and Network Access Control to detect and isolate suspicious activity, preventing lateral movement and reconnaissance by attackers. Outdated switches or devices that cannot enforce proper segmentation must be upgraded or replaced.

Human factors present additional risks. Continuous cybersecurity awareness training should target phishing, social engineering, and SWIFT-specific threats, while role separation ensures no individual has full control over transactions or system access. Employee activity should be monitored for anomalies, and clear consequences for policy violations must be communicated. Similarly, gaps in SWIFT CSP compliance must be addressed, ensuring all mandatory controls, including network isolation, MFA, and logging, are fully implemented and audited regularly.

Incident response and recovery processes must be developed and tested to minimize the impact of future attacks. Clear procedures should define roles, escalation, and communication with correspondent banks and authorities, enabling rapid containment and transaction reversal. Recovery processes must ensure systems can be restored quickly and SWIFT operations resumed safely using clean system images and verified backups. Red-team exercises simulating payment fraud, periodic control reviews, continuous threat modelling, and lessons-learned sessions should reinforce resilience and ensure the bank’s cybersecurity posture is continuously strengthened.

# Appendices & Supporting Documentation

## Appendix A– Critical Asset, MITRE ATT&CK Mapping & NIST Control Failures

| REF | Critical Asset | MITRE ATT&CK Technique and Description | Relevant NIST CSF Control | Observed Control Gap |
|---|---|---|---|---|
| 1. | Monitoring & Logging System | **T1595-Active Scanning**: Adversaries executed active network scans to gather information that can be used during targeting. | **DE.CM-03:** Personnel activity and technology usage are monitored to find potentially adverse events | Activity was logged but not actively monitored, so malicious actions went unnoticed. |
| | | **TA0005- Defense Evasion**: Adversaries leveraged gaps in monitoring and log correlation to remain undetected. | **PR.PS-04**: Log records are generated and made available for continuous monitoring | Logs were generated but not continuously reviewed or correlated, leaving attacks undetected. |
| 2. | SWIFT Operator Credentials | **T1056.001 –Input Capture (Keylogging):** Adversaries installed malware that captured user input directly from SWIFT terminals. | **PR.AC-07**: Users, devices, and other assets are authenticated (multifactor) commensurate with the risk of the transaction. | Absence of multifactor authentication allowed adversaries who captured credentials to log in as legitimate users. |
| | | **T1078 – Valid Accounts:** The stolen credentials were then used to authenticate as legitimate SWIFT operators, allowing adversaries to issue fraudulent SWIFT messages. | | |

| REF | Critical Asset | MITRE ATT&CK Technique and Description | Relevant NIST CSF Control | Observed Control Gap |
|---|---|---|---|---|
| 3. | SWIFT Terminals | **T1566-Physhing (Initial Access):** Adversaries gain access to the Terminals through phishing attacks. | **PR.PS-01: Security configuration management practices are established and applied:** This requires that the SWIFT terminal's hardware, OS, firmware, and applications are configured according to a secure baseline and maintained consistently. | SWIFT terminals were insufficiently hardened, permitting unauthorized processes and weak endpoint restrictions that increased exposure to compromise. |
| 4. | Transaction Verification Process (Printer) | **T1565 – Data Manipulation:** Adversaries altered verification outputs to conceal malicious activity, undermining the integrity of SWIFT transaction data. | **DE.CM-09:** The organization continuously monitors its systems, software, and the data they process to detect any unauthorized changes or other adverse activity. | Monitoring mechanisms were insufficient to detect tampering in verification outputs or SWIFT system records, allowing malicious alterations to go unnoticed |
| 5. | Internal Network Segments (Poor Segmentation) | **TA0008 – Lateral Movement:** Adversaries moved freely across the internal network due to poor segmentation, allowing their malware to spread and pivot between systems without restriction. | **PR.IR-01**: Networks and environments are protected from unauthorized logical access and usage. | Lack of network segmentation allowed attackers to move laterally between systems without restriction. |
| | | | **PR.PS-03**: Hardware is maintained, replaced, and removed commensurate with risk | Outdated switches were used, providing no support for VLANs or modern security controls. |
| 6. | Employees (Human Factor) | **T1566.001 – Spearphishing Attachment:** Attackers sent a fake job-application email with a malicious attachment, which the staff opened, giving the adversary initial access. | **PR.AT-01**: Personnel are provided with awareness and training so that they possess the knowledge and skills to perform general tasks with cybersecurity risks in mind. | Staff's limited cybersecurity awareness in spotting phishing attempts and recognising that the blank-page printer output was a critical red flag allowed the compromise to continue unnoticed. |

# REFERENCES


Darknet Diaries. (2020). *The Bangladesh Bank heist* [Episode 72]: Bangladesh Bank Heist – Darknet Diaries

Rahman, M. (2016). *A Forensic View of Bangladesh Bank Reserve Heist.* University of Dhaka. Retrieved from: ResearchGate

Zetter, K. (2016, May 17). That insane, $81M Bangladesh Bank heist? Here's what we know. *WIRED:*. https://www.wired.com/2016/05/insane-81m-bangladesh-bank-heist-heres-know/

Forbes Staff. (2016, May 13). Crooks behind $81M Bangladesh Bank heist linked to Sony Pictures Hackers. *Forbes:* https://www.forbes.com/sites/thomasbrewster/2016/05/13/81m-bangladeshbank-hackers-sony-pictures-breach/

Wikipedia contributors. (2025, April 15). *2016 Bangladesh Bank cyber heist*. In *Wikipedia*: https://en.wikipedia.org/wiki/2016_Bangladesh_Bank_cyber_heist

National Institute of Standards and Technology. (2018). *Framework for improving critical infrastructure cybersecurity* (Version 1.1): https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.04162018.pdf

MITRE. (2025). *ATT&CK®: Enterprise matrix:* https://attack.mitre.org/matrices/enterprise/

Veeam. (2023). *Backup & disaster recovery solutions for financial institutions*. https://www.veeam.com